

## 12 — Risk Register

A risk register with **13 risks** (the requirement is  $\geq 10$ ), using **custom scales** for probability and cost (deliberately **not** 0–1 probabilities and **not** dollar costs), an **exposure** value (Probability  $\times$  Cost), and a dedicated **mitigation plan for the biggest risk**.

### Files

- **Excel workbook:** [seatme-risk-register.xlsx](#) — generate it with the script below.
- **Generator script:** [generate\\_risk\\_register.py](#)
- **CSV fallback (same data):** [risks.csv](#)

### Generate the Excel file

```
pip install openpyxl
python generate_risk_register.py
# -> writes seatme-risk-register.xlsx
```

The workbook has three sheets:

1. **Scales** — the custom probability and cost scales and the exposure bands.
2. **Risk Register** — all risks with Probability, Cost, Exposure, colour-coded band, and mitigation, sorted by exposure (highest first).
3. **Top Risk Mitigation** — the detailed plan for the highest-exposure risk.

### Custom scales

**Probability (1–5):** 1 Rare · 2 Unlikely · 3 Possible · 4 Likely · 5 Almost certain.

**Cost / impact (1–5):** 1 Negligible · 2 Minor · 3 Moderate · 4 Major · 5 Severe.

**Exposure = Probability  $\times$  Cost** (1–25), banded:

| Band     | Exposure |
|----------|----------|
| Low      | 1–5      |
| Medium   | 6–12     |
| High     | 13–19    |
| Critical | 20–25    |

### Risks (sorted by exposure)

| ID  | Category    | Risk                                      | P | C | Exposure | Band |
|-----|-------------|-------------------------------------------|---|---|----------|------|
| R01 | Operational | AWS Academy lab reset wipes all resources | 4 | 4 | 16       | High |

| ID  | Category     | Risk                                                                | P | C | Exposure | Band   |
|-----|--------------|---------------------------------------------------------------------|---|---|----------|--------|
| R02 | Security     | API Gateway has no JWT authorizer (auth enforced in-Lambda)         | 3 | 5 | 15       | High   |
| R03 | Security     | Weak/leaked seeded admin credentials                                | 3 | 5 | 15       | High   |
| R04 | Delivery     | SNS confirm friction → invites not delivered                        | 4 | 3 | 12       | Medium |
| R05 | Delivery     | SES blocked → emails in spam / undelivered                          | 4 | 3 | 12       | Medium |
| R07 | Data         | Accidental teardown / no backups → data loss                        | 3 | 4 | 12       | Medium |
| R10 | Reliability  | Code regression breaks API on redeploy                              | 3 | 3 | 9        | Medium |
| R12 | Privacy      | No-login <code>?host=</code> link exposes event details (read-only) | 3 | 3 | 9        | Medium |
| R06 | Availability | Single-region outage → full downtime                                | 2 | 4 | 8        | Medium |
| R08 | Scalability  | DynamoDB 400 KB item limit for huge events                          | 2 | 4 | 8        | Medium |
| R09 | Security     | XSS via guest-supplied fields                                       | 2 | 4 | 8        | Medium |
| R13 | Config       | Placeholder injection fails → app can't reach API                   | 2 | 4 | 8        | Medium |
| R11 | Cost         | Cost overrun from spikes/abuse                                      | 2 | 3 | 6        | Medium |

## Biggest risk & mitigation (R01)

**R01 — AWS Academy lab reset wipes all resources** (Exposure 16, High).

Because the project runs in an AWS Academy lab whose session expires and whose **Reset** wipes every resource, a reset during grading would remove the live link and data.

### Mitigation:

1. **Infrastructure as code** — the whole stack redeploys with `python redeploy_all.py` in minutes, so a wiped environment is fully recoverable.
2. **Data export / backups** — export the DynamoDB `SeatMe` table (or enable point-in-time recovery / on-demand backup) before stopping the lab.
3. **Avoid the lab Reset button** — only stop/start the lab to preserve resources.
4. **Idempotent redeploy** — re-running updates resources in place with no manual cleanup.
5. **Documented credentials & demo link** — re-verify the app immediately after redeploy.
6. **Roadmap** — move to a standard AWS account (no lab expiry) and add DynamoDB global tables + multi-region S3 for durability.

Runner-up risks **R02** (open API) and **R03** (admin credentials) are the top security items; their mitigations are listed in the register and the Top Risk Mitigation sheet.